

ICS 35.040

CCS L 80

SL

中华人民共和国水利行业标准

SL/T 846—2025

水利重要数据安全保护要求

Requirements for the security protection of
water resources critical data

2025-08-01 发布

2025-11-01 实施

中华人民共和国水利部 发布

中华人民共和国水利部

关于批准发布《水利电子证照 第1部分：基本技术要求》等5项水利行业标准的公告

2025年第21号

中华人民共和国水利部批准发布《水利电子证照 第1部分：基本技术要求》（SL/T 816.1—2025）等5项水利行业标准，现予以公布。

序号	标 准 名 称	标准编号	替代标准号	发布日期	实施日期
1	水利电子证照 第1部分：基本技术要求	SL/T 816.1—2025		2025.8.1	2025.11.1
2	水利电子证照 第2部分：河道采砂许可证	SL/T 816.2—2025		2025.8.1	2025.11.1
3	水资源评价导则	SL/T 238—2025	SL/T 238—1999	2025.8.1	2025.11.1
4	水利水电工程移民安置验收规程	SL/T 682—2025	SL 682—2014	2025.8.1	2025.11.1
5	水利重要数据安全保护要求	SL/T 846—2025		2025.8.1	2025.11.1

水利部
2025年8月1日

目 次

前言 V

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 2

5 基本原则 2

6 重要数据识别和安全保护框架 2

 6.1 重要数据识别 2

 6.2 安全保护框架 2

7 数据安全管理制度 3

 7.1 数据安全管理制度 3

 7.2 数据安全管理机构 4

 7.3 数据安全人员管理 4

8 数据安全安全技术 5

 8.1 一般要求 5

 8.2 数据收集 5

 8.3 数据存储 6

 8.4 数据使用 7

 8.5 数据加工 8

 8.6 数据传输 8

 8.7 数据提供 9

 8.8 数据公开 9

 8.9 数据销毁 9

9 数据安全运营 10

 9.1 资产管理 10

 9.2 风险监测 10

 9.3 威胁管理 10

 9.4 风险评估 10

 9.5 应急处置 11

参考文献 12

前 言

根据水利技术标准制修订计划安排，按照 GB/T 1.1—2020《标准化工作导则 第 1 部分：标准化文件的结构和起草规则》的要求，编制本标准。

本标准共 9 章，主要技术内容有：

- 基本原则；
- 重要数据识别和安全保护框架；
- 数据安全治理；
- 数据安全技术；
- 数据安全运营。

请注意本标准的某些内容可能涉及专利。本标准的发布机构不承担识别专利的责任。

本标准批准部门：中华人民共和国水利部

本标准主持机构：水利部网络安全和信息化领导小组办公室

本标准解释单位：水利部网络安全和信息化领导小组办公室

本标准主编单位：水利部信息中心、北京金水信息技术有限公司

本标准出版、发行单位：中国水利水电出版社

本标准主要起草人：蔡 阳 付 静 张 潮 詹全忠 周维续 陈真玄 谢文君 沈智镔
邹 希 戴逸聪 张晓艺 韩松莘 魏方威 范宇楠 殷 悦

本标准审查会议技术负责人：刘 艳

本标准体例格式审查人：陈 昊

本标准在执行过程中，请各单位注意总结经验，积累资料，随时将有关意见和建议反馈至水利部国际合作与科技司（通信地址：北京市西城区白广路二条 2 号；邮政编码：100053；电话：010 - 63204533；电子邮箱 bzh@mwr.gov.cn；网址：<http://gjkj.mwr.gov.cn/jsjd1/bzcx/>）。

水利重要数据安全保护要求

1 范围

本标准规定了水利重要数据安全保护的基本原则、重要数据识别和安全保护框架，以及数据安全
管理、数据安全技术、数据安全运营等要求。

本标准适用于指导水利部、流域管理机构、地方水行政主管部门、水利工程管理单位等各级水利
部门开展重要数据安全保护建设和监督管理。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本标准必不可少的条款。其中，注日期的引用文
件，仅该日期对应的版本适用于本标准；不注日期的引用文件，其最新版本（包括所有的修改单）适
用于本标准。

GB/T 22239 信息安全技术 网络安全等级保护基本要求

GB/T 35273—2020 信息安全技术 个人信息安全规范

GB/T 36951 信息安全技术 物联网感知终端应用安全技术要求

GB/T 39786 信息安全技术 信息系统密码应用基本要求

GB/T 43697 数据安全技术 数据分类分级规则

GB/T 45574 数据安全技术 敏感个人信息处理安全要求

SL/T 803 水利网络安全保护技术规范

3 术语和定义

下列术语和定义适用于本标准。

3.1

重要数据 critical data

特定领域、特定群体、特定区域或达到一定精度和规模的，一旦被泄露或篡改、损毁，可能直接
危害国家安全、经济运行、社会稳定、公共健康和安全的的数据。

注：仅影响组织自身或公民个体的数据一般不作为重要数据。

[来源：GB/T 43697—2024，3.2]

3.2

数据安全 data security

通过采取必要措施，确保数据处于有效保护和合法利用的状态，以及具备保障持续安全状态的
能力。

[来源：GB/T 41479—2022，3.4]

3.3

数据处理者 data processor

在数据处理活动中自主决定处理目的、处理方式的组织、个人。

[来源：GB/T 43697—2024，3.11]

3.4

去标识化 de-identification

通过对个人信息的技术处理，使其在不借助额外信息的情况下，无法识别或者关联个人信息主体
的过程。

[来源：GB/T 35273—2020，3.15]

4 缩略语

下列缩略语适用于本标准。

SQL：结构化查询语言（Structured Query Language）

App：应用程序（Application）

SOAP：简单对象访问协议（Simple Object Access Protocol）

RESTful：表现层状态转化（Resource Representational State Transfer）

gRPC：谷歌远程过程调用（Google Remote Procedure Call）

VPN：虚拟专用网络（Virtual Private Network）

SSL：安全套接字层（Secure Socket Layer）

API：应用程序接口（Application Programming Interface）

5 基本原则

水利重要数据安全保护基本原则如下：

- a) 合规有效原则：应确保重要数据处理活动的合规性和正当性，应依据本标准和网络安全等级保护、信息系统密码应用等国家标准规范要求开展数据安全保护。
- b) 权责一致原则：应按“谁管业务，谁管业务数据，谁管数据安全”的原则，梳理数据处理活动涉及的业务部门、技术部门等，明确数据安全保护责任和义务。
- c) 全程可控原则：应采取必要的管控机制和技术措施，确保重要数据在数据处理活动各环节的机密性、完整性和可用性。
- d) 持续完善原则：应定期更新重要数据目录，根据数据的重要性、面临的数据安全威胁、已有的数据安全措施等，持续完善数据安全保护措施。
- e) 统筹协调原则：应统筹发展和安全，协调业务应用需求和安全保护措施，促进数据安全保护和业务应用共同发展。
- f) 安全可信原则：应采用安全可靠的网络产品和服务。

6 重要数据识别和安全保护框架

6.1 重要数据识别

重要数据识别要求如下：

- a) 应对数据资产（包括原始数据和衍生数据）进行梳理，形成数据资产情况表。
- b) 应依据 GB/T 43697 和水利行业数据分类分级制度标准，确定数据资源所属的类别和级别，识别重要数据，形成重要数据目录。
- c) 应全面梳理重要数据基本情况、责任主体、处理环节、相关参与者信息、出境情况、安全保护情况等。
- d) 应根据数据类别和级别的定期评审结果，及时更新重要数据目录。

6.2 安全保护框架

水利重要数据安全保护应以重要数据识别为前提和基础，对数据实行分类分级保护，加强对重要数据的重点保护。安全保护框架宜包含数据安全治理、数据安全技术、数据安全运营，如图 1 所示，具体内容如下：

- a) 数据安全治理应建立数据安全管理制度、明确数据安全管理机构、加强数据安全人员管理，

从管理层面落实数据安全保护要求。

- b) 数据安全技术应围绕数据收集、存储、使用、加工、传输、提供、公开、销毁等数据处理活动全流程采取技术管控措施。
- c) 数据安全运营应从资产管理、风险监测、威胁管理、风险评估、应急处置等方面，持续监控、检测、分析和响应数据安全威胁和风险。

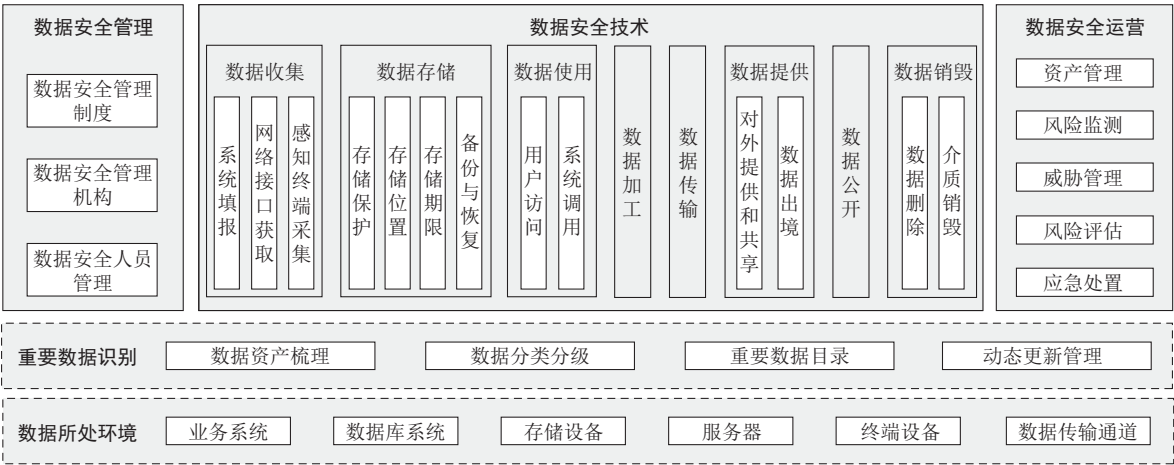


图 1 水利重要数据安全保护框架

7 数据安全

7.1 数据安全管理制度

7.1.1 数据安全管理制度及实施细则应覆盖全部数据处理活动，具体如下：

- a) 应明确数据安全总体策略、方针、目标和原则。
- b) 应深度融合业务流程，建立数据安全日常管理及操作规程，对数据处理活动各环节的数据安全保护措施提出具体要求。
- c) 应建立数据安全审查要求与操作程序；数据处理活动可能影响国家安全的，应对数据处理的目的、范围、方式、安全防护措施、可能带来的风险等进行评估，并按要求申报数据安全审查，评估和审批记录应留存 3 年以上。
- d) 应建立数据处理权限申请与审核机制，申请中应明确数据使用目的、内容、时限、技术防护措施等，审批记录应留存 3 年以上。
- e) 应建立数据处理活动各环节相关记录表单，宜采用电子化手段实现记录和审核。
- f) 应建立数据安全风险监测预警机制，加强数据安全风险监测、分析、研判、预警的统筹协调。
- g) 应建立数据安全事件管理、处置规程和应急响应等机制，明确数据安全事件的处置流程及应对方法。

7.1.2 应加强数据处理过程中第三方组织的安全管理，具体如下：

- a) 委托第三方组织建设、运行或维护数据基础设施，存储或加工数据的，应通过合同或协议等形式，明确第三方组织的数据安全保护责任和义务；应对第三方组织的数据安全保护能力、资质进行评估和核实。
- b) 向第三方组织提供或共享数据的，应与接收数据的第三方组织签订合同或协议等法律文件，约定数据提供和共享的目的、范围、方式、数据量、安全防护措施、数据返还或销毁方式等；应明确第三方组织发生收购、兼并、重组、破产时，需要继续履行的相关数据安全保护义务。
- c) 应对第三方组织履行数据安全保护义务进行监督，发现第三方组织落实安全管理责任有问题

的，应及时督促整改或停止数据处理权限。

7.1.3 应通过正式、有效的方式发布数据安全管理制度及实施细则，确保相关职能部门、岗位和人员知悉。

7.1.4 应定期审核和更新数据安全管理制度及实施细则。

7.1.5 在组织架构发生重大调整或业务发生重大变化时，应及时评估和修订数据安全管理制度及实施细则。

7.2 数据安全管理机构

7.2.1 应明确数据安全责任人，领导数据安全保护和重大数据安全事件处置工作，组织研究解决重大数据安全问题。

7.2.2 应明确数据安全管理机构，具体负责数据安全保护工作，履行下列职责：

- a) 研究提出数据安全相关重大决策建议。
- b) 组织制定数据安全总体策略、发展规划、管理制度、实施细则和数据安全事件应急预案。
- c) 组织开展数据分类分级工作，建立并维护重要数据目录。
- d) 组织开展数据安全风险监测、风险评估、应急演练、宣传教育培训等活动，督促和协调安全隐患整改工作。
- e) 报告数据安全保护和事件处置情况。
- f) 组织受理和处置数据安全投诉、举报。

7.2.3 数据安全管理机构内应设立数据库管理员、数据安全管理员、数据安全审计员等数据安全关键岗位，做到职责分离：

- a) 数据库管理员负责数据库系统的日常运行维护。
- b) 数据安全管理员负责数据安全策略的实施、数据安全风险监测与处置。
- c) 数据安全审计员负责对数据库管理员、数据安全管理员操作行为等进行审计。

7.2.4 业务部门、信息系统建设部门、信息系统运维部门应设立数据安全岗位，履行下列工作职责：

- a) 根据数据安全相关策略、制度、细则等，落实本部门数据安全保护责任。
- b) 严格履行授权审批程序，为相关方分配数据权限。
- c) 对本部门数据处理活动各环节的数据安全管控措施有效性进行确认。
- d) 配合数据安全风险评估及检查检测等工作。
- e) 制定本部门数据安全应急预案，并定期开展数据安全应急演练。
- f) 处置本部门数据安全事件。
- g) 记录本部门数据处理活动日志。

7.3 数据安全人员管理

7.3.1 岗位权限

岗位权限要求如下：

- a) 应定期梳理更新数据安全关键岗位人员清单。
- b) 应明确数据库管理员、数据安全管理员、数据安全审计员等数据安全关键岗位的数据处理权限，落实专人专岗要求。
- c) 数据安全关键岗位人员录用或上岗前，应进行背景审查，并签署岗位安全责任协议。
- d) 应定期对数据安全相关岗位人员进行评估和技能考核。
- e) 在人员离岗时，应立即终止并收回其数据处理权限，明确告知其继续履行有关信息的保密义务，并签订保密承诺书。

- f) 外部人员在访问数据资源前，应预先提出书面或电子化申请，明确访问的数据资源及权限，批准后由专人开设账户、分配权限，并登记备案。
- g) 应要求外部人员签订数据安全协议。

7.3.2 教育培训

教育培训要求如下：

- a) 应制定年度数据安全培训计划，培训宜分为面向数据安全相关岗位人员的安全专项培训和面向全体员工的安全意识培训。
- b) 应针对数据库管理员、数据安全管理员、数据安全审计员等不同数据安全岗位，在培训计划中明确细化培训内容、培训时间、培训时长、考核评定等相关要求。
- c) 应根据实际情况及时调整或定期更新培训计划。
- d) 每年应至少开展 1 次数据安全专项培训。

8 数据安全技术

8.1 一般要求

8.1.1 处理重要数据的系统应不低于 GB/T 22239 第三级安全要求和 SL/T 803 第三级安全要求，应通过网络安全等级保护测评。

8.1.2 处理重要数据的系统密码应用要求应不低于 GB/T 39786 第三级规定，应通过商用密码应用安全性评估。

8.1.3 应在网络安全防护的基础上，采取身份鉴别与访问控制、加密、脱敏、备份、审计等技术措施，保证重要数据处理活动全流程数据安全；数据处理活动涉及个人信息的，应遵循 GB/T 35273、GB/T 45574 的规定对个人信息进行保护。

8.1.4 应对重要数据处理活动各环节进行记录，确保重要数据处理活动可审计、可追溯；审计日志应包括操作主体、操作客体、操作时间、操作类型、操作结果等内容，审计日志留存时间应不少于 6 个月。

8.2 数据收集

8.2.1 基本要求

数据收集基本要求如下：

- a) 应明确数据收集的目的、规模、方式、范围、频度、类型、存储期限、存储地点等，并在收集前进行安全评估，确保数据收集符合国家和行业有关规定。
- b) 应遵循最小必要原则，收集的数据应为满足业务所必需的最少数量。
- c) 应采取合法、正当的方式收集数据。
- d) 除 GB/T 35273—2020 中 5.6 规定的情形外，收集个人信息前，应向个人信息主体告知收集、使用个人信息的目的、方式和范围等规则，并获得个人信息主体的授权同意。
- e) 应采用数据标记、数据血缘分析等技术措施，实现收集的数据源头可溯源。
- f) 应采用密码技术对数据收集过程中的身份鉴别数据进行保护，防止身份鉴别数据泄露、篡改。

8.2.2 系统填报

系统填报要求如下：

- a) 应对登录填报设备、系统的人员进行身份鉴别和权限控制；宜采用数字证书、二维码、短信

验证码、动态口令等方式进行身份鉴别；宜充分利用已有统一身份认证服务。

- b) 涉及数据批量修改等敏感操作时，应采用实人核验、二次校验等手段加强保护。
- c) 应对收集数据的内容、格式进行鉴别和校验，防止 SQL 注入、恶意文件上传等网络攻击以及错误数据归档入库。
- d) 宜采用消息摘要、消息认证码、数字签名等技术，保证收集过程数据的完整性。
- e) 宜采用密码技术，保证收集过程数据的机密性。
- f) App、网页应用程序等客户端相关业务完成后应及时对缓存进行清理，不应留存相关数据。

8.2.3 网络接口获取

网络接口获取要求如下：

- a) 应验证接口的真实性，宜采用 IP 绑定、数字证书等技术进行校验。
- b) 宜采用消息摘要、消息认证码、数字签名等技术，保证收集过程数据的完整性。
- c) 宜采用密码技术，保证收集过程数据的机密性。
- d) 应对接口获取数据进行质量监控并定期分析，及时对异常或错误数据进行修正。

8.2.4 感知终端采集

感知终端采集要求如下：

- a) 感知终端应用安全宜符合 GB/T 36951 的有关要求。
- b) 感知终端宜通过物联网网关接入水利业务网，应基于网络身份标识、MAC 地址或数字证书等对感知终端的身份进行认证。
- c) 应能够拒绝非授权、认证超时、超过规定次数认证失败的感知终端接入。
- d) 感知终端宜采用消息摘要、消息认证码、数字签名等技术保证其采集的数据的完整性。
- e) 感知终端在传输其采集到的数据时，宜采用密码技术保证数据的机密性。

8.3 数据存储

8.3.1 存储保护

存储保护要求如下：

- a) 应采用密码技术保证结构化数据、非结构化数据存储的机密性和完整性，宜充分利用统一密码基础设施服务资源。
- b) 宜结合业务实际，对原始数据进行脱敏、去标识化后存储；脱敏、去标识化后的数据应与用于还原数据的信息分开存储。
- c) 应最小化数据访问权限，宜在防火墙、操作系统、数据库系统等进行安全配置。
- d) 应对访问数据存储区域设备、系统等进行身份鉴别和权限控制，应采用固定终端、运维安全管理与审计系统等方式开展运维操作。

8.3.2 存储位置

存储位置要求如下：

- a) 在中国境内收集和产生的数据应在境内存储，存储数据的数据中心、云平台等不应设置在境外。
- b) 应为数据存储划分专门的网络区域，数据存储区域与其他网络区域间应配置有效的网络隔离措施，且数据存储区域不应部署在网络边界处。
- c) 数据库系统、存储系统等应禁止互联网直接访问。

d) 应采取流量监测、数据库审计等手段，对不同区域间的数据流动进行监测管控。

8.3.3 存储期限

存储期限要求如下：

- a) 应根据业务需要、管理要求等，综合确定数据存储期限，在存储期限到期前，应提示数据处理器。
- b) 应对超过存储期限或已不需要的数据设置标志位，并应按照 8.9 有关要求，及时销毁相关数据。

8.3.4 备份与恢复

备份与恢复要求如下：

- a) 应建立完备的数据备份策略，备份策略中应至少说明备份数据放置场所、数据传递方式、备份方式、备份周期或备份频率、备份数据范围等。
- b) 应具备同城、异地数据备份能力，实现数据实时增量备份和定期全量备份。
- c) 生产数据宜采用本地备份结合同城、异地容灾，历史数据可采用光盘等方式进行归档。
- d) 应采取技术措施保证数据恢复过程中的数据安全，确保恢复过程中不会造成数据泄露、数据破坏等问题。
- e) 应定期评估备份数据的可用性、完整性和一致性，定期开展备份数据恢复测试。

8.4 数据使用

8.4.1 用户访问

用户访问要求如下：

- a) 应对数据访问进行细粒度权限管控，综合考虑主体角色、业务需要、时效性等因素，将数据访问范围限制在最小的范围内。
- b) 数据批量查询、批量修改、批量下载等高风险操作宜采取实人核验、二次校验等鉴别方式，宜充分利用已有统一身份认证服务。
- c) 宜对应用系统访问数据库进行权限管控、风险阻断等，宜对应用服务器上数据库配置文件等进行加密保护。
- d) 应定期对数据的访问权限进行梳理，及时清理过期账号、闲置账号及其授权。
- e) 应能够限制数据访问速率、频率，宜对数据大量或频繁查询、下载等可疑操作进行监控预警、限制和阻断。
- f) 数据展示宜采用脱敏、水印、限制复制、去标识化等技术措施，数据展示完成后应及时将展示数据从用户本地缓存中清除。
- g) 数据下载或导出时应采用加密、脱敏、去标识化等技术手段防止数据泄露，宜采用水印等技术实现数据的可追溯性。
- h) 应严格限定数据库、业务系统的管理、运维等特权账号的设置和使用：
 - 1) 应明确特权账号使用场景和使用范围，建立特权账号的审批授权机制，并严格控制特权账号数量，及时注销停用的账号。
 - 2) 应将特权账号与指定网络地址绑定，应对特权账号的操作记录进行监控和审计，宜与经审批授权的范围进行比对，实现自动告警和阻断。
 - 3) 应合理分配特权账号权限，应禁止特权账号修改和删除审计日志。
 - 4) 宜采用动态脱敏、加密保护等措施加强特权账号运维过程中数据保护。

8.4.2 系统调用

系统调用要求如下：

- a) 应制定统一的接口使用规范，应使用 SOAP、RESTful、gRPC、WebSocket 等主流成熟接口方式提供服务，宜优先使用域名作为接口地址。
- b) 宜对接入或嵌入接口的数据接收方应用系统开展技术检测，确保其数据处理行为符合双方约定及接口使用规范，发现超出双方约定的行为应及时停止接入。
- c) 应建立完善的接口认证鉴权机制，对数据接收方进行身份验证，宜采用 IP 绑定、数字证书等方式进行校验。
- d) 应对接口上线、变更、下线等环节进行统一管理，接口上线前应进行风险评估；接口上线后应对接口运行异常、恶意调用等采取告警、阻断等措施；应定期对无业务流量或已下线业务的接口进行清理。
- e) 应建立接口安全控制策略，明确使用接口的限制条件和安全措施；应采用接口参数过滤、限制等防注入措施；宜对接口使用范围、使用期限、使用频度、流量、行为等进行统一监测和管控。

8.5 数据加工

数据加工要求如下：

- a) 应明确数据加工过程中数据获取方式、访问接口、授权机制、安全防护措施、处理结果安全防护等内容。
- b) 应对接入数据库、大数据、存储系统等的数据计算分析设备、系统、组件等采取身份鉴别、访问控制、恶意代码防范等防护措施。
- c) 数据加工过程中使用的外部软件开发包、组件、源码等，应进行安全检测和评估。
- d) 宜使用经脱敏、去标识化处理后的数据。
- e) 应对数据加工过程进行监控，对识别到的异常行为进行实时告警和阻断。
- f) 数据加工场景涉及跨系统、跨主体的，宜采用同态加密、多方安全计算等隐私计算技术，降低数据加工过程中数据泄露、窃取等风险。
- g) 数据加工过程中，发现可能危害国家安全、公共安全、经济安全和社会稳定的，应立即停止加工活动。
- h) 数据加工过程中，开展用户画像、信息推送、内容呈现等人工智能业务的，宜从科技伦理和可解释性等方面对智能算法使用进行规范。

8.6 数据传输

数据传输要求如下：

- a) 向行业内单位进行数据传输，应采用水利业务网建立传输通道；向行业外单位进行数据传输，宜采用专线、国家电子政务外网等传输通道；确需采用互联网传输数据的，应开展安全评估。
- b) 应在数据传输前，通过 IP 地址绑定、数字证书校验等方式，对通信实体身份进行验证。
- c) 跨网络区域传输数据前，应采用 VPN 技术或 SSL 协议构建加密传输通道。
- d) 宜采取消息摘要、消息认证码、数字签名等措施，保证数据在传输过程中的完整性。
- e) 应在不同网络区域或安全域之间设置细粒度的安全管控策略，对数据传输至外部主体的情况进行重点监控。
- f) 应对数据传输过程进行实时监测，发现数据异常传输行为时应进行告警和阻断。
- g) 应在数据传输不完整时清除传输缓存数据，应在数据传输完成后立即清除传输历史缓存数据。

8.7 数据提供

8.7.1 对外提供和共享

对外提供和共享数据要求如下：

- a) 数据接收方系统网络安全保护等级应高于或等于数据提供方系统网络安全保护等级。
- b) 应采取数据水印、脱敏、加密、签名等技术措施，保证数据提供和共享过程安全。
- c) 向数据接收方提供个人信息，应向个人信息主体告知数据接收方的名称、联系方式、处理目的、处理方式、个人信息的种类、存储期限等，并取得个人信息主体的单独同意。
- d) 通过网络进行数据提供和共享时，包括但不限于接口、服务、文件共享协议、数据库访问等，应通过身份鉴别、数据加密、反爬虫机制、攻击防护和流量监控等手段，防止数据泄露、丢失、非法获取、非法利用等风险；应定期检查和评估数据提供和共享方式的安全性和可靠性。

8.7.2 数据出境

数据出境要求如下：

- a) 应按照数据出境有关规定向国家网信部门或省级网信部门申报并通过数据出境安全评估。
- b) 数据出境前，应对数据进行脱敏、去标识化处理。
- c) 应采取技术和管理措施，在既定目的、范围、方式和数据类型、规模等之内进行数据跨境传输，不超出向国家申报数据出境安全评估时明确的事项等向境外提供数据。
- d) 应综合考虑数据出境期限、国家规定的留存期限，确定数据出境相关日志和审批记录留存时间。
- e) 应对数据跨境传输业务进行识别和全过程监测和管控。
- f) 应采取必要的技术和管理措施，防止境内访问流量路由至境外。

8.8 数据公开

数据公开要求如下：

- a) 不宜公开的数据不应公开，确需公开的，应对拟公开数据的内容、形式、范围、期限是否合法、正当、必要，以及安全防护和管理措施的有效性进行评估。
- b) 应记录数据公开情况，包括数据公开的日期、规模、目的、范围等。
- c) 通过公众服务网页进行数据公开时，应采取技术措施实现网页防篡改和数据防爬取。
- d) 应对数据采取脱敏、去标识化、禁用复制等措施，降低数据在公开环节的泄露风险。
- e) 应评估已公开数据潜在的聚合性风险，对不适宜继续公开或超出公开期限的数据采取停止公开、召回、销毁等处理措施。

8.9 数据销毁

8.9.1 数据删除

数据删除要求如下：

- a) 应对以下数据进行删除：
 - 1) 开发、测试、分析等使用需求执行完毕的数据。
 - 2) 超出法律法规规定或者约定的存储期限的数据。
 - 3) 其他需要删除的数据。
- b) 宜建立双人审批机制，避免数据误删除。
- c) 进行数据删除时，应通过多次覆写等方式安全地擦除数据，多次覆写填充的字符应完全覆盖

存储数据区域，确保数据不可再被恢复或以其他形式被利用。

- d) 应同步对备份数据进行删除。
- e) 应对数据删除有效性进行复核和评估，验证数据删除效果。
- f) 应对数据删除过程留存日志，记录数据删除的审批、实施过程，以及被删除数据的具体情况。
- g) 应在删除数据后及时更新重要数据目录。

8.9.2 介质销毁

介质销毁要求如下：

- a) 应建立介质销毁双人审批机制，对数据存储介质销毁全过程进行记录，并定期对介质销毁记录进行检查和审计。
- b) 对数据存储介质进行报废处理时，应采用消磁、焚烧、粉碎等不可恢复的方式，以确保数据不能被恢复。

9 数据安全运营

9.1 资产管理

资产管理要求如下：

- a) 应定期开展数据资产识别，掌握数据源、数据类型、数据级别、责任人、数据量、访问控制规则等信息。
- b) 应利用技术工具建立全网的数据资产台账和数据视图，管理、监测和审计数据资产分布、使用、流转等。
- c) 宜建立统一的数据标签体系，对数据的元数据、数据类别级别、数据源等进行标记和跟踪，构建和维护数据血缘关系。

9.2 风险监测

风险监测要求如下：

- a) 应采用流量分析、态势感知等技术措施对网络和区域边界流量、重要业务系统访问行为、数据库连接等进行实时监测，发现违规传输、非法访问、流量异常等情况应及时告警。
- b) 应建立数据处理活动的监测规则和安全基线，应能够根据预先定义的阈值或设置的规则对异常数据处理活动进行发现、跟踪和告警。
- c) 宜构建统一的数据安全风险监测平台，集中汇集数据安全相关日志信息，统一处理数据安全相关风险，实现数据资产发现、风险场景监测、数据流转链路分析等安全能力。
- d) 应配置专人进行数据安全风险监测和审计日志分析处置。
- e) 应汇集数据供应链信息，对供应链安全风险开展监测处置。

9.3 威胁管理

威胁管理要求如下：

- a) 应对数据安全威胁开展分类别分级别管理。
- b) 应将数据安全威胁与上级主管部门、行业单位等来源的数据安全情报进行协同分析。
- c) 应定期汇总分析数据安全威胁情况，制定实施修复优化措施。
- d) 应定期上报数据安全威胁情况。

9.4 风险评估

9.4.1 应建立数据安全风险评估程序，定期或者在组织、组织环境及数据处理活动发生重大变化时

开展数据安全风险评估，采取必要的措施对识别的风险进行控制。

9.4.2 风险评估内容包括但不限于：

- a) 数据处理者基本信息。
- b) 本年度数据处理的目的、规模、方式、范围、类型、存储期限、存储地点等，不包括数据内容本身。
- c) 数据安全管理制度及实施情况，数据备份、脱敏、加密、访问控制、审计等安全保护措施及有效性。
- d) 数据委托处理、数据提供和共享、数据出境等风险评估情况。
- e) 发现的数据安全风险，发生的数据安全事件及处置情况。
- f) 对已识别出的数据安全风险的防控措施。
- g) 未来风险预判或意见建议。

9.4.3 风险评估报告和风险处理情况记录应保存 3 年以上。

9.5 应急处置

9.5.1 应急响应

应急响应要求如下：

- a) 应制定数据安全应急预案，包括应急组织机构与职责、数据安全事件分类分级、监测预警、应急处置流程、保障措施等事项。
- b) 应保证充足的应急响应所需的资源，包括人员、设备、场所、工具、资金等。
- c) 应定期组织开展应急演练，宜与网络安全应急演练协同开展。
- d) 应根据应急演练结果或在数据处理系统自身或外部环境发生重大变化时，对应急预案进行及时修订。
- e) 应建立与网信、公安等部门的数据安全事件应急处置协调沟通渠道。
- f) 宜建立数据安全集中管控平台，对数据库审计系统、数据防泄漏系统、API 安全防护系统、日志审计平台等数据安全相关设备进行统一管理，实现数据安全事件联动处置。

9.5.2 事件处置

事件处置要求如下：

- a) 数据安全事件发生时，应按照应急预案启动应急响应，及时进行处置、记录和报告。
- b) 数据安全事件记录中应包括但不限于以下内容：发现事件的人员、时间、地点，发生事件的系统名称，涉及数据规模、类型，可能的影响，已采取或拟采取的处置措施等。
- c) 数据安全事件应在规定时间内处置完成并关闭。
- d) 事件处置结束后，应分析总结原因和存在的问题，在 5 个工作日内向上级主管部门报告事件原因、危害后果、责任处置、改进措施等情况。

参 考 文 献

- [1] GB/T 35274—2023 信息安全技术 大数据服务安全能力要求
 - [2] GB/T 39477—2020 信息安全技术 政务信息共享 数据安全技术要求
 - [3] GB/T 41479—2022 信息安全技术 网络数据处理安全要求
 - [4] GB/T 45396—2025 数据安全技术 政务数据处理安全要求
 - [5] GB/T 45577—2025 数据安全技术 数据安全风险评估方法
 - [6] SL/T 799—2020 水利数据目录服务规范
 - [7] 办信息〔2022〕256号 水利部办公厅关于印发《水利数据分类分级指南（试行）》的通知
-